MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 039 · SEPTEMBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

FIELD GUIDE · INCIDENT RESPONSE

An Incident Response Tabletop Exercise That Satisfies 3.6.3

An incident response tabletop exercise counts for NIST 800-171 3.6.3 only if it leaves evidence. How to seat, script, and document one an assessor accepts.

BY **PATRICK CARUSO**

READING TIME · 7 MIN

INCIDENT-RESPONSE · TABLETOP-EXERCISE · NIST-800-171 · DFARS · CMMC

ost incident response tabletop exercises fail as evidence for the same reason they feel successful in the room: the conversation was good, people nodded, and nothing was written down that an assessor could examine a year later. NIST SP 800-171 requirement 3.6.3 is six words long - "Test the organizational incident response capability" - and it is worth a single point in the DoD Assessment Methodology. That low weight is exactly why programs treat it as a meeting with snacks.

The weight is misleading. The 800-171A objective for 3.6.3 asks only whether the capability is tested, but what gets tested is 3.6.1, an operational incident-handling capability spanning preparation, detection, analysis, containment, recovery, and user response, and 3.6.2, which requires incidents to be tracked, documented, and reported to identified officials and authorities. Those two carry five points each, and under 32 CFR 170.21 neither can be parked on a POA&M for a conditional Level 2 status the way 3.6.3 can (the eligibility rules are here). A tabletop that satisfies 3.6.3 is one that leaves behind a test plan, a record of who decided what, an after-action report, and a revised plan. The assessor's examine list for 3.6.3 names incident response test plans, testing materials, and test results. Build to that list.

With CMMC Phase II assessments suspended while the Reform Task Force review runs, that record still matters: DFARS 252.204-7012 and the 110 requirements behind your SPRS score remain in force, and the exercise is how you know your affirmation is true.

Write the test plan before you book the room

Start with the document an assessor examines first. The test plan names the incident response plan version under test, the objectives (which 3.6.1 and 3.6.2 objectives this scenario exercises), the systems in scope, and what a pass looks like. "Participants discussed a ransomware event" is not a pass criterion. "The team identified who files the DIBNet report and confirmed that person's certificate is current" is.

Fix the scope to your CUI boundary as the system security plan draws it. An exercise about a corporate marketing site tests nothing 7012 cares about.

Seat the people who would actually be awake at 2 a.m.

The roster is part of the evidence, and the most common gap is that it lists titles instead of the people who hold the authority. At minimum: the incident response lead, the executive who can authorize taking a production system offline, whoever runs the enclave day to day (in-house or the managed service provider), the program or contracts manager who talks to the prime and the contracting officer, and counsel or whoever stands in for counsel.

Two seats get missed more than any other. One is the person who files the report at DIBNet. The other is whoever holds the DoD-approved medium assurance certificate that paragraph (c)(3) of the clause requires in order to report at all. Sometimes they are the same person; the exercise should establish that, name a backup, and record when the certificate expires. The 72-hour clock article walks why that credential decides the deadline; this exercise is where you prove it will not.

Pick a scenario that lives inside the CUI boundary

A good scenario is specific enough that the team cannot answer in generalities. Three that map to real 7012 decisions:

Ransomware on the enclave file share. Encryption starts on the server holding CUI drawings. This forces the containment question with a regulatory edge: pull the plug, reimage, and restore from backup, or preserve the images the clause requires first.

A subcontractor reports compromise of a CUI drawing set you sent them. Your own network may be untouched. The decision is whether it is, and paragraph (m) matters here: a sub under the flowed-down clause reports directly to DoD and owes its prime the DoD-assigned incident report number. Does your team know to ask for it?

Your cloud provider notifies you of an incident. Paragraph (b)(2)(ii)(D) makes you require and ensure that a cloud service provider holding covered defense information complies with the clause's reporting, malware, preservation, and forensic-access paragraphs. The exercise tests whether that notice lands in a mailbox anyone reads, and whether your agreement gets you what you need.

A tabletop an assessor accepts is not a better conversation. It is a conversation with a scribe, a clock, and a list of decisions somebody had to own.

Run the injects that force the decisions

Injects are timed facts the facilitator releases one at a time, each designed to require a decision rather than a discussion. For the ransomware scenario, a workable sequence:

1. **Detection.** An endpoint alert fires on the enclave file server outside business hours. Who is called, and who declares an incident?
2. **Classification.** Is this a "cyber incident" under 7012? The clause defines one as actions through computer networks resulting in a compromise or "an actual or potentially adverse effect" on a system or its information. Certainty that CUI left is not the threshold. Record the decision and its time.
3. **Containment versus evidence.** IT wants to wipe and restore by morning. Paragraph (e) requires preserving images of all known affected systems and relevant monitoring and packet capture data for at least 90 days from report submission. What gets imaged, by whom, and where is it stored?
4. **Malware.** A sample of the encryptor is isolated. Paragraph (d) says it goes to the DoD Cyber Crime Center (DC3), and explicitly not to the contracting officer. Who knows the submission path?
5. **Scope.** Logs show the compromised account also touched the engineering share outside the enclave. The paragraph (c)(1)(i) review extends to other systems that may have been accessed. Does the boundary change?
6. **Reporting.** Somebody must file. The facilitator asks for the certificate holder by name, and whether the certificate works today.
7. **The prime.** You are a subcontractor on this program. Who sends the prime the incident report number, and when?
8. **Recovery and users.** Engineers need the drawings back for a delivery date. What do you tell staff, and what is the restore criterion?

Swap the specifics for the sub and cloud scenarios; keep the pattern of each inject ending in a named decision.

Keep the record while it happens

Assign a scribe who is not a participant. For every inject, log the time, the decision, who made it, and anything the team could not answer. The unanswered items are the point: "nobody knew where the DC3 instructions were" is a finding, and findings are what make the exercise a test rather than a rehearsal.

This is the part MacTech productized. Its IR tabletop kit runs 6 to 8 scripted injects with a facilitator console that timestamps decisions as they are made, and the showcase walk-through maps each inject to the incident response control it exercises. A spreadsheet and a disciplined scribe can do the same job; what cannot be skipped is capturing it in the moment.

Close the loop in the plan, not the slide deck

The after-action report turns the log into evidence: an executive summary, the timeline, findings tied to the 3.6.1 and 3.6.2 objectives they touch, and corrective actions with an owner who is a person, a target date, and a tracking reference. Then comes the step that separates a test from an event - the incident response plan

FIELD COPY
ISSUE Nº 039
INCIDENT RESPONSE

1

SPRS POINT CARRIED BY 3.6.3, THE REQUIREMENT TO TEST THE INCIDENT RESPONSE CAPABILITY

10

SPRS POINTS CARRIED BY 3.6.1 AND 3.6.2 TOGETHER - THE CAPABILITY THE TEST IS SUPPOSED TO PROVE

90 days

MINIMUM IMAGE AND MONITORING-DATA PRESERVATION UNDER DFARS 252.204-7012(E), COUNTED FROM REPORT SUBMISSION

◆ WHAT 3.6.3 LEAVES TO YOU

The Rev 2 requirement sets no frequency and names no format. Its discussion lists checklists, walk-throughs, tabletop exercises, simulations, and comprehensive exercises as valid tests. Your incident response plan has to pick the cadence, and then your records have to show you kept it.

gets revised, with a version number and change history that point back to the exercise that caused the change. A missing backup certificate holder becomes a named alternate. A 30-day log retention gap becomes a ticket.

File the package together: test plan, roster with roles, scenario and inject script, decision log, after-action report, corrective action tracking, and the redlined plan. Update the 3.6.3 narrative in the SSP to cite it and state the cadence your plan commits to. Next year's exercise should open by checking whether this year's corrective actions closed, because an assessor reading two consecutive reports will check that first. ◆